# SHIELD-AI Glossary

Plain-language definitions of the terms used in our briefings

Security Architecture Practice

October 5, 2026

Abstract
A short glossary for executives, boards, and program managers meeting AI security vocabulary for the first time.

# SHIELD-AI Glossary

Terms are grouped the way you will meet them in a briefing. Definitions are written for a non-technical reader; the technical meaning is included where it matters.

## The core concepts

**Agentic AI (agent).** An AI system that does not just answer questions but takes actions: sending email, editing code, calling APIs, spending money, changing configuration. An agent has tools, and tools can do damage.

**Autonomy.** How much an agent can do without a human in the loop. Low autonomy: suggests, waits for approval. High autonomy: acts, reports afterwards. Most security incidents involve agents whose autonomy was set higher than their guardrails.

**Tool.** A capability an agent can call: an API, a database query, a shell command, a web action. Each tool is a potential attack surface. The framework treats tools as the central risk: an agent is only as safe as its tools.

**Prompt injection.** Hiding instructions inside content an agent reads. A document, a web page, or a comment can contain text that tells the agent to do something the user never asked for. This is the AI equivalent of a phishing email, and it is the most common attack class in the incident ledger.

**Sandbox.** A contained environment where an agent runs, with limited access to the host system and the network. A sandbox is only as good as its configuration; several major incidents happened because the sandbox was misconfigured, not because it was missing.

**Guardrail.** A rule or control that constrains what an agent can do. Guardrails sit between the model and the action.

**Maturity level (L1-L4).** A four-step scale used throughout the framework, consistent with ISM and the Essential Eight: L1 Initial, L2 Managed, L3 Defined, L4 Optimised. It gives a repeatable way to describe posture.

## The framework mechanics

**Pillar.** One of the seven security domains of the framework: Model Security, Identity and Access, Data Security, Tool and Pipeline Security, Monitoring and Incident Response, Governance and Risk, Execution Environment.

**Control.** A specific, testable security requirement, numbered within its pillar (for example MS-04, TP-10). SHIELD-AI has 67 controls. Each maps to one or more regulatory obligations and to documented incidents.

**Policy as code.** Expressing security rules as machine-readable code instead of prose. SHIELD-AI controls are written as Rego rules evaluated by an OPA policy engine. The advantage: rules can be tested, versioned, and enforced automatically, and an audit becomes a test run.

**Deny-override.** The evaluation rule used by the policy engine: if any control says deny, the action is blocked, even if another control allows it. It is the opposite of allow-override, where an exception can quietly weaken security. Deny-override fails closed.

**Fail closed.** If the security system cannot confirm an action is safe (engine down, config missing, dependency unreachable), the action is blocked. Fail-open, by contrast, lets the action through when the control is unavailable, which is how several real-world breaches happened.

**Sidecar.** A small security service that runs next to the application and intercepts its traffic. SHIELD-AI's reference implementation deploys as a sidecar, which means existing platforms can be protected without rebuilding them.

**Reference implementation.** The working example architecture that ships with the framework: the components, diagrams, and policy engine that show how the controls are deployed in practice.

## The technology vocabulary

**MCP (Model Context Protocol).** A standard way for agents to connect to external tools and data. Because MCP servers can execute commands, they have become a favourite attack surface; several 2026 incidents involved exposed or poisoned MCP servers.

**Rego.** The policy language used by OPA, the open-source policy engine. It is how SHIELD-AI controls are expressed as executable rules.

**OPA (Open Policy Agent).** An open-source engine that evaluates policy rules. It is the enforcement core of the reference implementation.

**LLM (Large Language Model).** The model that powers the agent: GPT, Claude, Gemini, and open-weight alternatives. The framework is model-agnostic; the controls protect the system around the model, not the model itself.

**RAG (Retrieval-Augmented Generation).** Giving a model access to a document store so it can answer from your data. The retrieval step is an injection point: documents can contain hidden instructions.

**SBOM (Software Bill of Materials).** A list of the components in a piece of software. The framework requires SBOMs for models and dependencies so supply-chain attacks can be traced.

**Egress.** Outgoing network traffic. Egress controls restrict which external destinations an agent can reach; several evaluation-harness escapes happened because egress was left open.

## The regulatory vocabulary

**ISM (Information Security Manual).** The Australian government's security standard, published by the Australian Cyber Security Centre.

**Essential Eight (E8).** ACSC's baseline of eight mitigation strategies for cyber security.

**SOCI Act.** The Security of Critical Infrastructure Act, which imposes obligations on critical infrastructure operators.

**CPS 234.** APRA's prudential standard on information security for banks, insurers, and superannuation funds.

**CPG 230.** APRA's guidance on managing information security risk, including third-party and outsourcing risk.

**PSPF.** The Protective Security Policy Framework, applying to Australian government entities.

**Privacy Act / APP 11.** The Australian Privacy Act and its Australian Privacy Principle 11, which requires organisations to protect personal information from misuse, loss, and unauthorised access.

**ASIC.** The Australian Securities and Investments Commission, which has stated expectations for AI governance in financial services.

**AU Guardrails.** The Australian government's proposed mandatory guardrails for AI in high-risk settings.

---

*Plain-language definitions are for briefings. Where a definition differs from the technical meaning, the framework document is authoritative.*

*SHIELD-AI Glossary – v1.18 edition, October 5, 2026*